Elementos vulnerables del sistema informático

Ejercicios para el alumnado · Seguridad y Alta Disponibilidad · 2.º ASIR

Nombre y apellidos: Adrián Sayas Descalzo_____ Fecha: _____

Aprenderás a identificar debilidades en hardware, software, datos, infraestructura, personal y red, explicar sus consecuencias y proponer medidas justificadas. Trabaja con los apartados 3, 3.1 y 3.2 del temario. No necesitas configurar equipos ni ejecutar ataques.

Ejercicio 1 Detectamos las debilidades

25 minutos · Por parejas · Lee los seis casos y completa la ficha de la página siguiente.

Caso A

Un servidor tiene los ventiladores obstruidos por polvo y se apaga cuando aumenta su temperatura.

Caso B

Una aplicación sin actualizar mantiene un fallo de seguridad conocido que permite modificar registros sin permiso.

Caso C

Una carpeta de expedientes permite a cualquier usuario leer y modificar todos los documentos, aunque no los necesite.

Caso D

El cuarto de equipos está en un sótano con antecedentes de inundación y no tiene control de acceso.

Caso E

El centro no ha formado al personal para reconocer mensajes fraudulentos. Una empleada introduce su contraseña en una web que imita el correo corporativo.

Caso F

Una regla del cortafuegos permite conexiones externas a un servicio interno que no debería estar expuesto. Nadie revisa las alertas de red.

Puede haber varias categorías implicadas. Elige la principal según la debilidad descrita y añade otras si las justificas. Que el daño final afecte a los datos no convierte automáticamente toda debilidad en una vulnerabilidad de datos.

Ficha de análisis de los casos

Para cada caso indica el elemento principal, la debilidad concreta, una consecuencia y una medida relacionada con ella. Puedes completar las respuestas en una hoja adicional.

Caso	Elemento y debilidad	Consecuencia	Medida y justificación
A	Hardware : Ventiladores obstruidos por polvo	El servidor puede sobrecalentarse y apagarse	Limpiar los ventiladores y hacer un mantenimiento periódico.
B	Software : Aplicación sin actualizer y con un fallo conocido.	Se pueden modificar registros sin autorización.	Actualizar la aplicación y aplicar los parches de seguridad correspondientes.
C	Datos: Permisos excesivos para los usuarios.	Ususarios no autorizados podrían leer o modificar elementos.	Aplicar el principio mínimo de privilegio.
D	Infraestructura : Riesgo de inundación y falta de control de acceso.	Los equipos podrían dañarse y personas no autorizadas acceder al servidor.	Proteger el cuarto y controlar el acceso físico.
E	Personal: Falta de formación para el phishing.	Se pueden robar credenciales y acceder a sistemas.	Formar al personal y uhtilizar autenticación multifactor.
F	Red : Un servicio interno está expuesto a Internet	Un atacante podría intentar acceder al servicio.	Cerrar la regla innecesaria y revisar las alertas.

Conectamos los elementos

1. Elige un caso y explica cómo la debilidad de un elemento puede afectar a otros dos.

En el caso E, la falta de formación del personal puede provocar el robo de credenciales. Esto puede afectar a la red, ya que podría permitir accesos no autorizados, datos , y a datos que podrían ser consultados o modificados._____

2. Escoge una medida de tu tabla e indica un riesgo que seguiría existiendo después de aplicarla.

Si actualizamos una aplicación, se corrige la vulnerabilidad conocida, pero podrían aparecer nuevas vulnerabilidades. Por eso es necesario mantener el software actualizado y revisarlo periódicamente.

Ejercicio 2 Plan de mejora del centro

35 minutos · Grupos de 3 o 4 · Vuestro equipo asesora a un centro de formación.

El centro abre sus matrículas mañana. El servidor guarda expedientes y gestiona las inscripciones. Los cortes eléctricos son frecuentes y no hay SAI. La única copia de los expedientes está en ese mismo servidor. Recepción utiliza una cuenta compartida con permisos de administración. El cuarto de equipos queda abierto y hay una tubería con fugas sobre el servidor. La aplicación lleva meses sin actualizarse. El cortafuegos permite acceder desde Internet a un servicio interno sin necesidad. Nadie tiene asignada la revisión de alertas ni la formación del personal.

Solo podéis iniciar tres actuaciones hoy. Elegidlas teniendo en cuenta la urgencia, el daño posible y la apertura de matrículas. No hay una única selección correcta; debéis justificar el orden.

N.º	Debilidad que atenderéis	Actuación y motivo de prioridad
1	Única copia de los expedientes en el mismo servidor.	Realizar una copia de seguridad externa. Es prioritaria porque una avería, inundación o ataque podría provocar la pérdida de todos los expedientes.
2	Servicio interno accesible desde Internet.	Cerrar la regla innecesaria del cortafuegos. Reduce inmediatamente la exposición del sistema a accesos externos.
3	Tubería con fugas sobre el servidor y cuarto abierto.	Proteger el servidor y restringir el acceso al cuarto. Evita daños físicos y accesos no autorizados.

Para cada actuación, indicad quién debe encargarse y qué evidencia permitirá comprobar que se ha realizado correctamente.

Actuación	Responsable propuesto	Comprobación
1	Administrador de sistemas	Comprobar que la copia existe y realizar una prueba de restauración.
2	Administrador de sistemas/redes	Revisar la regla y comprobar que el servicio ya no es accesible desde Internet.
3	Responsable de mantenimiento y sistemas	Comprobar que la fuga está solucionada y que el cuarto queda cerrado y controlado.

¿Qué debilidades quedan pendientes y qué medidas combinaríais después para cubrir tecnología, formación y gestión?

Quedan pendientes actualizar la aplicación, eliminar la cuenta compartida de administración, instalar un SAI, revisar las alertas de seguridad y formar al personal. Después se deberían combinar medidas técnicas, como actualizaciones, SAI y monitorización, con formación del personal y procedimientos de gestión y revisión.

Preparad una defensa de dos minutos. Otra pareja o grupo os preguntará por una limitación de vuestro plan. Anotad vuestra respuesta en una hoja adicional.

Comprobación individual de conceptos

15 minutos · Sin apuntes · Responde brevemente y corrige después con otro color.

1. Diferencia elemento vulnerable y vulnerabilidad con un ejemplo de hardware.

El elemento vulnerable es el componente que puede sufrir un problema, mientras que la vulnerabilidad es su debilidad. Por ejemplo, el servidor es el elemento y tener los ventiladores obstruidos es la vulnerabilidad.

2. Un corte eléctrico afecta a un servidor. ¿Qué puede aportar un SAI y qué limitación tiene?

Un SAI proporciona electricidad temporal cuando hay un corte y permite apagar el servidor correctamente. Su limitación es que funciona durante un tiempo limitado y no sustituye a un generador.

3. ¿Por qué una aplicación puede seguir siendo vulnerable aunque el edificio esté protegido?

Porque la seguridad física no protege frente a vulnerabilidades del software. Una aplicación sin actualizar puede ser atacada aunque el edificio tenga buenas medidas de seguridad.

4. Alguien consulta expedientes sin permiso, pero no los modifica. ¿Qué propiedad de la información se ve afectada?

Se ve afectada la confidencialidad, porque una persona no autorizada ha podido acceder a información.

5. Se alteran notas sin autorización. ¿Qué propiedad se ve afectada? ¿Y si el sistema deja de estar accesible?

Si se alteran notas, se afecta la integridad.

Si el sistema deja de estar accesible, se afecta la disponibilidad.

6. ¿Por qué conviene combinar formación del personal con medidas técnicas?

Porque las medidas técnicas pueden evitar muchos ataques, pero los usuarios también pueden cometer errores. La formación ayuda a prevenir errores como caer en un mensaje de phishing.

7. Explica el principio de privilegio mínimo con una cuenta de recepción.

Consiste en dar a cada usuario solo los permisos que necesita. Por ejemplo, recepción debería poder gestionar matrículas, pero no tener permisos de administrador.

8. ¿Qué efecto principal tiene un ataque DDoS sobre el servicio?

Un DDoS intenta saturar un servicio con muchas solicitudes, provocando que deje de estar disponible para los usuarios legítimos.

9. ¿Un cortafuegos de red protege frente a una inundación? Justifica.

No. Un cortafuegos protege principalmente las comunicaciones de red. Una inundación es un riesgo físico y necesita medidas como protección del cuarto, sensores o traslado de los equipos.

10. ¿Una auditoría elimina todos los riesgos? Indica para qué sirve y qué hay que hacer después.

No, una auditoría sirve para detectar y evaluar riesgos y debilidades. Después hay que aplicar medidas correctoras y revisar que funcionen correctamente.

Qué entregar

Los seis casos analizados, las dos preguntas de relación, el plan con tres prioridades y comprobaciones, la respuesta al otro grupo y esta comprobación individual.

Adrián Sayas Descalzo